

ZeToD Platform — OWASP Security Pass

Build In Africa Program | Week 5 | June 2026
Prepared by: Kenneth Omoregie (Project Lead)

This document records the results of a basic OWASP security checklist review conducted during Week 5 (The Hardening) of the Build In Africa program. All items were reviewed against the live production deployment.

A01 — Broken Access Control

Check	Status	Notes
Protected routes require authentication	PASS	ProtectedRoute.jsx checks Supabase session before rendering /dashboa
Unauthenticated users redirected to /login	PASS	Navigate to="/login" implemented in ProtectedRoute
JWT tokens not hardcoded in source code	PASS	JWT_SECRET stored in GitHub Secrets only
Backend routes validate JWT before responding	PASS	JWT middleware applied to all protected endpoints

A02 — Cryptographic Failures

Check	Status	Notes
HTTPS enforced on frontend	PASS	Vercel enforces HTTPS on all deployments
HTTPS enforced on backend	PASS	Render enforces HTTPS on all deployments
Passwords not stored in plain text	PASS	Supabase Auth handles password hashing (bcrypt)
JWT secret is strong and rotated	PASS	JWT_SECRET rotated during Week 5 hardening
No sensitive data in frontend source	PASS	All keys stored as VITE_ env vars in Vercel

A03 — Injection

Check	Status	Notes
Input validation on register endpoint	PASS	Backend validates email format and password length
Input validation on login endpoint	PASS	Backend validates required fields before processing
SQL injection prevention	PASS	Supabase uses parameterised queries — no raw SQL
No eval() or dangerous JS execution	PASS	No dynamic code execution in frontend or backend

A05 — Security Misconfiguration

Check	Status	Notes
Debug routes removed from production	PASS	/debug-sentry route removed during Week 5
No hardcoded secrets in repository	PASS	All secrets in GitHub Secrets and Vercel env vars
Error messages do not expose internals	PASS	Sentry captures errors internally; generic messages shown to users
CORS configured on backend	PASS	Express CORS middleware configured
Environment variables not committed to repo	PASS	.env is in .gitignore

A07 — Identification and Authentication Failures

Check	Status	Notes
Rate limiting on auth endpoints	PASS	express-rate-limit applied to /api/auth routes in Week 3
OAuth implemented via trusted provider	PASS	Supabase Auth handles Google and GitHub OAuth
Sessions invalidated on logout	PASS	supabase.auth.signOut() called on logout
Minimum password length enforced	PASS	Minimum 8 characters enforced on register (frontend + backend)

Security Pass Summary

Category	Checks	Passed	Failed
A01 — Broken Access Control	4	4	0
A02 — Cryptographic Failures	5	5	0
A03 — Injection	4	4	0
A05 — Security Misconfiguration	5	5	0
A07 — Auth Failures	4	4	0
TOTAL	22	22	0

ZeToD passed all 22 OWASP security checks reviewed during Week 5. The platform is considered production-ready from a basic security standpoint.

Report prepared: June 2026 | ZeToD Platform | Build In Africa Program